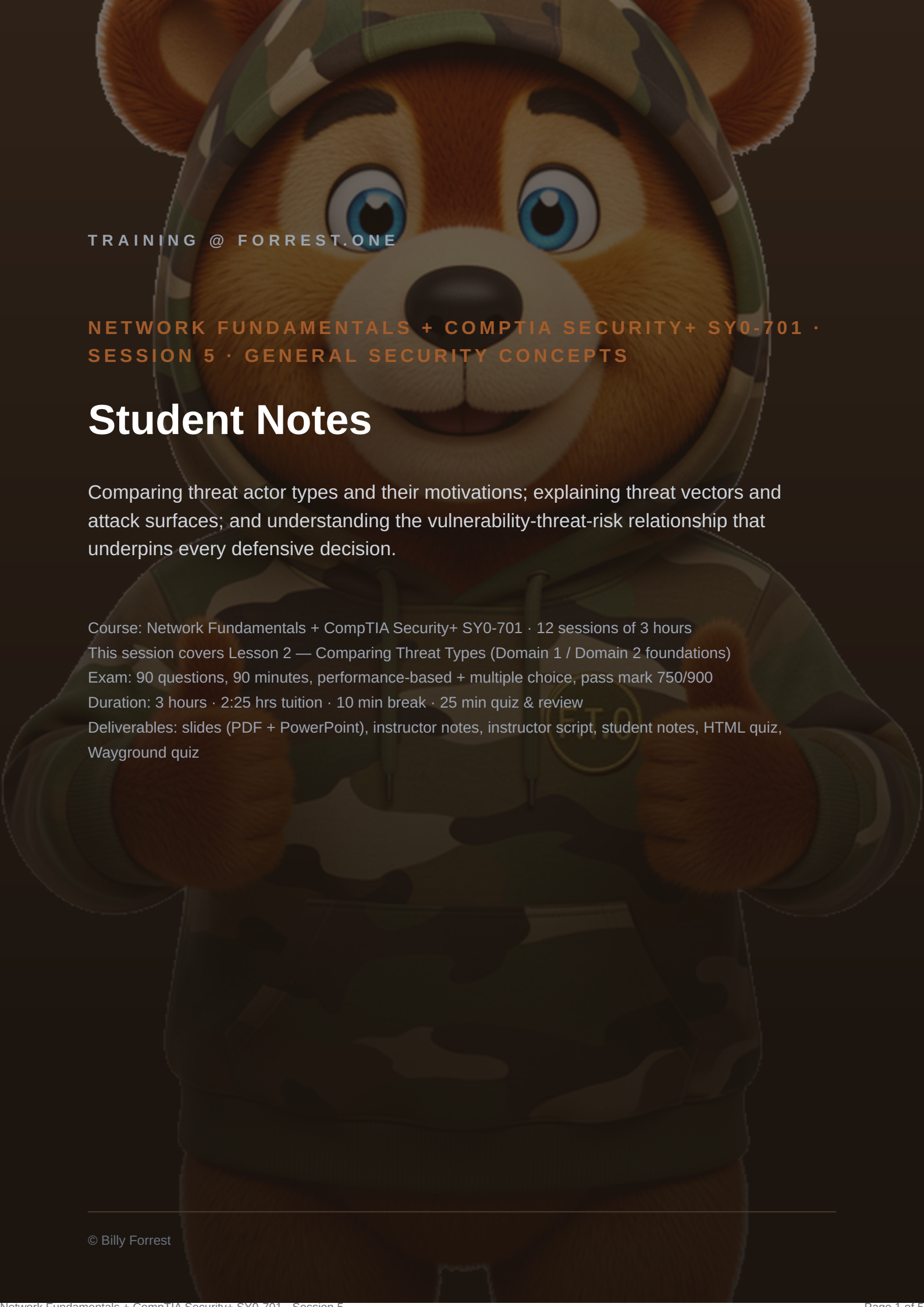




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 5 · GENERAL SECURITY CONCEPTS

Student Notes

Comparing threat actor types and their motivations; explaining threat vectors and attack surfaces; and understanding the vulnerability-threat-risk relationship that underpins every defensive decision.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session covers Lesson 2 — Comparing Threat Types (Domain 1 / Domain 2 foundations)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Student Notes, Threat Actors, Attack Surfaces & Vectors

Your revision guide for Session 5. This is the whole of Domain 2 (Threats, Vulnerabilities and Mitigations, 22% of the exam) in six chapters: the actors, the attack surface, the vulnerabilities, the malware, the network attacks, and the mitigations. Read alongside the slides, then use the self-check questions and the session quiz to confirm you are exam-ready.

Key terms

Term	Definition
Vulnerability	A weakness in a system, process or design
Threat	A person, tool or method that could exploit a vulnerability
Risk	The likelihood and impact of a threat exploiting a vulnerability
Threat actor	A person or group that poses a threat
APT	Advanced Persistent Threat: a long-term, stealthy, strategic campaign, state-backed or highly resourced
False flag	Techniques that mislead attribution towards another actor
Shadow IT	Unauthorised apps, devices or cloud services used outside approved controls
Attack surface	Every point where an attacker can enter or extract data
Threat vector	A path or method used to gain access or deliver a payload
Spear phishing	Targeted, personalised phishing aimed at a named individual
Whaling	Spear phishing aimed at executives and key decision makers
Pretexting	A fabricated scenario used to extract information
Baiting	A tempting lure, such as a dropped USB drive
Tailgating	Following an authorised person through a secure door
Watering hole	Compromising a site the target trusts, then delivering malware from it
Zero day	A vulnerability unknown to the vendor with no available patch
Misconfiguration	Insecure settings such as open ports, weak rules or exposed storage
Botnet	Many compromised machines, called zombies, controlled by one operator

Term	Definition
Command and control	The servers that issue orders to bots and collect their results
Double extortion	Stealing data as well as encrypting it, then threatening to publish
Credential stuffing	Replaying username and password pairs stolen in an earlier breach
Password spraying	A few common passwords tried across many accounts, under the lockout threshold
Injection	Input that changes what a query or command does
Denial of service	Making a service unavailable to legitimate users
Amplification	A small spoofed request that produces a large reply aimed at the victim
On-path attack	Relaying traffic between two parties who believe they are talking directly
Segmentation	Dividing a network into isolated zones to contain an attack
Least privilege	The minimum access needed to do the job, and nothing more
Hardening	Removing unnecessary services, software, ports and features

Core concepts

Chapter 1 · Know the adversary

Risk = threat × vulnerability. Actors are compared by resources, sophistication, motivation and intent. Motivations: financial, political or ideological, strategic, personal and ethical. Types: nation-state actors and APTs (espionage, disruption, persistence, false flags), organised crime (profit, ransomware, BEC, crime as a service), hacktivists (ideology, defacement, denial of service), unskilled attackers (ready-made tools), malicious and negligent insiders, shadow IT, and competitors (intellectual property, disinformation).

Chapter 2 · The attack surface

Every point where an unauthorised user could enter or extract data: hardware, software, networks, processes and people. Cloud, mobile, Internet of Things and remote work all expand it. Common vectors: phishing email, malware, software vulnerability, social engineering, wireless and cloud. Human vectors: the phishing family (phishing, spear phishing, whaling, smishing, vishing), then pretexting, baiting, tailgating, shoulder surfing and dumpster diving. Network and file vectors: unsecured wireless, rogue access points, on-path, malicious documents, infected executables and removable media. Direct access, remote access (VPN, RDP, SSH), open service ports, default credentials and the watering hole complete the picture.

Chapter 3 · Vulnerabilities

Supply chain (compromised updates, vendor credentials) and software (unpatched systems, misconfiguration, zero-day). Application and web: memory injection, buffer overflow, race conditions, SQL injection, cross-site scripting, cross-site request forgery and session hijacking. Operating system and hardware: privilege escalation, kernel exploits, end-of-life and legacy systems, BIOS and UEFI attacks, side channels, Spectre

and Meltdown. Mobile, cloud and virtualisation: jailbreaking, sideloading, lost devices, misconfigured storage, insecure interfaces, shared responsibility confusion, virtual machine escape and hypervisor flaws.

Chapter 4 · Malware and credential attacks

Lifecycle: delivery, exploitation, persistence. Types: virus (needs a user), worm (self-propagating), trojan (disguised). Evasion: polymorphism, encryption, rootkits, code obfuscation and fileless malware.

Ransomware, double extortion, spyware, keyloggers, rootkits and bootkits. Botnets: zombies, command and control, domain generation algorithms, fast flux and peer to peer. Credential attacks: brute force, dictionary, spraying, stuffing, offline hash attacks and rainbow tables.

Chapter 5 · Attacks on the network

Injection: SQL, command, LDAP, directory traversal and interface abuse, answered by validation, escaping and parameterised queries. Denial of service: volumetric, protocol, application layer, distributed and amplification. Layer 2: VLAN hopping, address table flooding, ARP poisoning and Spanning Tree attacks, answered by port security, DHCP snooping, dynamic ARP inspection and BPDU guard. DNS: poisoning, spoofing and hijacking, answered by DNSSEC, encrypted DNS and monitoring. Rogue devices and on-path attacks, answered by encryption and certificate validation. Physical and cryptographic attacks: device theft, malicious USB devices, badge cloning, downgrade, birthday and collision, and side channels.

Chapter 6 · Mitigation

Segmentation: VLANs, subnets and microsegmentation, so an attacker cannot move freely between zones. Access control: least privilege, need to know, separation of duties and regular entitlement reviews. Hardening and patching: remove what is unnecessary, change default credentials, close unused ports, apply firmware updates, build from CIS or NIST baselines, then inventory, assess, test, deploy and verify. Isolation: sandboxing, containerisation and air gaps. The attack chain: recon, vector, exploit, act.

Practical cautions

- Do not call all hackers criminals; ethical testing and responsible disclosure are legitimate work.
- Do not forget the negligent insider; the employee who falls for phishing is more common than the malicious one.
- Do not use 'APT' for every advanced attack; persistence and strategy are the point.
- Do not treat a virus and a worm as the same thing; only a worm spreads without the user.
- Do not assume backups defeat ransomware; double extortion steals the data first.
- Do not ignore the human vectors; most intrusions start with a person, not a port.
- Do not assume patching fixes everything; end-of-life and zero-day flaws need other controls.
- Do not treat vulnerability and risk as the same thing; risk needs a threat behind the weakness.
- Do not leave shadow IT out of the actor list; unauthorised services place data outside your controls.
- Do not confuse a spoofed DNS answer with a poisoned cache; spoofing leaves the resolver untouched.

Self-check questions

Answers are in your session slides

If you cannot answer a self-check from memory, revisit the corresponding slide, then retake the quiz.

Exam tips for Session 5

- Scenario questions reward classification; label the actor, the vector, the weakness or the control, and give two labels when both apply.
- Learn the attack-to-control pairs from chapters four and five; objective 2.5 asks for the purpose of the mitigation.
- APT means persistence and strategy, not just sophistication.
- Insider threat includes accidents, not just malice.
- Supply chain is an increasingly tested vector; know the NotPetya update example.
- Know the difference between a vulnerability and a risk; the exam tests the distinction directly.
- Name the phishing family member precisely; the target defines the type.
- Remember the Layer 2 defences by name: port security, DHCP snooping, dynamic ARP inspection and BPDU guard.

Further reading

- Network Fundamentals + CompTIA Security+ SY0-701 Exam Objectives, objectives 2.1 to 2.5.
- NCSC threat reports, real-world actor profiles and motivations.
- MITRE ATT&CK, techniques mapped to actor groups.
- Case write-ups of Stuxnet, WannaCry and NotPetya for concrete examples of an APT campaign and a supply chain compromise.